

HUM34-3

Digital Threats & Cybersecurity

Threat actors, attack surfaces, influence operations, and the governance of cyber risk

Cybersecurity as an institutional and governance problem, not a technical one.

Albert School — 12 hours

Preface

In *Law Fundamentals & GDPR* (HUM24-2) you learned to read law as institutional architecture: a set of rules deliberately designed by humans, encoding particular values, and always incomplete. You met GDPR as the keystone case — privacy and dignity turned into enforceable obligations — and you previewed the wider EU digital rulebook: the AI Act, the DSA, and the DMA. That architecture is the foundation this course stands on. Here we watch what happens when that carefully designed architecture meets an adversary who is actively trying to break it.

That is the central move of this module. Cybersecurity is usually taught as a technical subject — encryption, firewalls, protocols. We will do almost none of that. We treat cybersecurity as a problem of **governance, risk, and institutions**: who the attackers are and what they want, why organisations stay vulnerable even when the technical fixes are known, how states weaponise information, and which institutions are supposed to regulate all of this — and where they fail. The deliverable skill is to look at a real digital asset or a real incident and write an analysis a non-technical decision-maker — a CEO, a minister, a board — can act on.

A word on why this matters now. The concurrent *Geopolitics III* course supplies the state-actor backdrop: cyberspace has become a domain of conflict between states, and many of the incidents we study are episodes in that larger contest. When you read about a ransomware gang or a disinformation campaign, the question “who ultimately benefits, and is a state standing behind this?” is never far away.

The course moves in a deliberate order. We first build a vocabulary of **threats** (Chapter 1) and the concept that organises them, the **attack surface** (Chapter 2). We then turn to the **actors** who exploit those surfaces and the disturbing market in **zero-day** vulnerabilities they trade in (Chapter 3). From attacks on machines we move to attacks on minds — **disinformation, influence operations, and information sovereignty** (Chapter 4). Chapter 5 hands you a **risk-assessment framework** you can apply to a concrete asset, and Chapter 6 lays out the **regulatory architecture** — ANSSI, ENISA, CISA, NIS2, and GDPR’s breach rules — that is supposed to govern all of it. Chapter 7 pulls everything together into the two capstone genres of the course: the **incident briefing** and the reading of **cyber conflict as a geopolitical instrument**.

Throughout, the test of your understanding is not whether you can define a term but whether you can use it to explain a real event and advise a real decision-maker.

Contents

Preface	2
1 The cybersecurity threat taxonomy	3
1.1 The five core categories	3
1.2 A named incident for each	4
2 The attack surface	4
2.1 Why the human and organisational layers dominate	5
3 Actors, zero-days, and the exploit market	6
3.1 The four actor classes	6
3.2 Zero-days and the exploit market	7
3.3 The state’s dilemma: stockpile or disclose	7
4 Disinformation, influence operations, and information sovereignty	8
4.1 Disinformation versus misinformation	8
4.2 Anatomy of an influence operation	8

4.3	Information sovereignty	9
5	Risk assessment for digital assets	10
5.1	The framework	10
5.2	Proportionality and the decision-maker	11
6	The regulatory and institutional architecture	11
6.1	The agencies	11
6.2	The legal obligations	11
6.3	Where the gaps are	12
7	Cyber conflict and the incident briefing	12
7.1	Cyber conflict as a geopolitical instrument	12
7.2	Writing the incident briefing	13

1 The cybersecurity threat taxonomy

Before you can defend anything you need a vocabulary for what can go wrong. The trap is to treat that vocabulary as a list of technical curiosities. It is not. Each threat category is defined by **what the attacker is trying to achieve** and **how the victim organisation typically fails** — which is exactly what a decision-maker needs to know.

Worked example — five break-ins, five logics. A burglar can pick your lock (malware), phone pretending to be the police and ask you to open the door yourself (phishing), change the locks and demand payment for the new key (ransomware), block your street with so many fake delivery vans that nobody can get in or out (DDoS), or bribe the company that installs everyone's locks so that every house in the city ships with a hidden flaw (supply-chain compromise). The physical analogy already tells you the important thing: these are five **different logics of attack**, not five flavours of the same thing, and each demands a different defence and a different conversation with leadership.

1.1 The five core categories

Definition 1 The core threat categories are:

- **Malware** — malicious software (viruses, worms, trojans, spyware) that runs on a target system to steal, destroy, surveil, or seize control.
- **Phishing** — deception that manipulates a human into revealing credentials, transferring money, or running malware; *spear phishing* targets a specific named person.
- **Ransomware** — malware that encrypts the victim's data and demands payment for the decryption key; modern variants also **exfiltrate** data and threaten to leak it (*double extortion*).
- **DDoS** (Distributed Denial of Service) — overwhelming a service with traffic from many machines (a *botnet*) so legitimate users cannot reach it.
- **Supply-chain compromise** — attacking a trusted supplier so that the malicious code or access is delivered to the supplier's many customers through a legitimate, signed channel.

The reason supply-chain compromise frightens defenders most is that it turns the victim's own trust against them: the malicious update arrives through the exact channel the organisation is supposed to trust.

1.2 A named incident for each

You will be expected to attach a **named incident** to each category — both because it anchors the abstraction and because incidents are the currency of professional discussion. The following are the canonical references for this course.

Category	Named incident	Why it is the reference case
Malware	Stuxnet (2010)	A worm that physically destroyed Iranian uranium centrifuges — the first malware widely understood to cause physical damage, and a state-built weapon.
Phishing	Twitter (2020)	Spear-phishing of employees gave attackers admin tools; high-profile accounts were hijacked for a crypto scam. The breach was of people , not code.
Ransomware	Colonial Pipeline (2021)	DarkSide ransomware shut down the largest US fuel pipeline; a single leaked password and a missing second factor triggered a national fuel panic.
DDoS	Dyn / Mirai (2016)	A botnet of hijacked webcams and routers flooded a DNS provider, knocking out Twitter, Netflix, and Reddit — insecure consumer devices weaponised at scale.
Supply chain	SolarWinds (2020)	Malicious code was hidden in a legitimate, signed update of Orion network software, reaching 18,000 organisations including US federal agencies.

Table 1: The five core threat categories, each with the named incident that serves as this course’s reference case. Notice that two of the five — Twitter and Colonial Pipeline — turned on a **human or organisational** failure, not a clever exploit. That pattern is the subject of the next chapter.

Common pitfall Students reflexively rank these threats by technical sophistication and conclude that the exotic ones (Stuxnet) are the “real” danger. For most organisations the reverse is true: the overwhelming majority of damaging breaches begin with **phishing** or a **stolen password** — cheap, unglamorous, and aimed at people. A threat taxonomy ranked by sophistication misleads the decision-maker; rank by **frequency and impact on your actual organisation** instead.

2 The attack surface

The single most useful concept in the course is the **attack surface**. It reframes the defender’s question from “is our software secure?” to “what is the complete set of ways an adversary could get in?” — and that set is mostly not technical.

Worked example — the same breach, three retellings. Colonial Pipeline is usually told as a technical story: ransomware encrypted the billing systems. But ask *how the attacker got in* and the story changes. The entry point was a single VPN account, no longer in use, whose

password had been reused and leaked, and which had no second authentication factor. So: a **technical** gap (no MFA), an **organisational** gap (a dormant account never decommissioned), and a **human** gap (a password reused across services). Fix only the technical layer and the other two doors stay open.

Definition 2 The **attack surface** of an organisation is the total set of points at which an adversary could attempt to gain access or cause harm. It has three layers:

- **Technical** — software vulnerabilities, misconfigurations, unpatched systems, exposed services, weak cryptography.
- **Organisational** — processes and structures: dormant accounts, excessive access rights, absent logging, no incident plan, unmanaged suppliers.
- **Human** — the people: susceptibility to phishing, weak or reused passwords, social-engineering pressure, fatigue, insider risk.

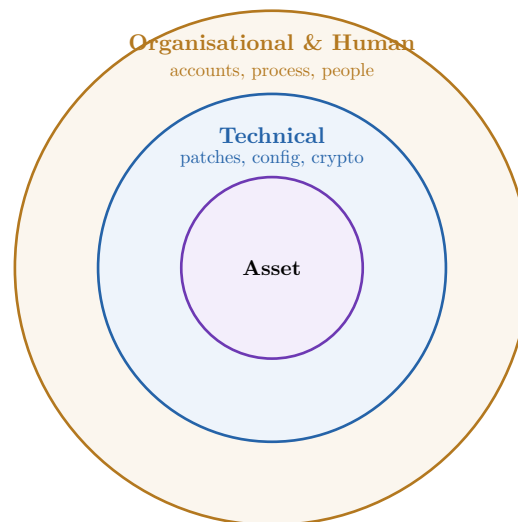


Figure 1: The attack surface as nested layers around the asset. Defenders instinctively harden the inner technical ring, but most real intrusions enter through the outer rings — a phished employee or an unmanaged account. The surface is only as small as its widest-open layer.

2.1 Why the human and organisational layers dominate

Technical defences improve every year, so attackers increasingly route around them through people and process. This is not a moral point about careless employees; it is structural. A phishing email costs almost nothing to send and needs to succeed only once. An organisation must defend every person, every day, against every attempt — an asymmetry that no amount of technical hardening alone can close.

Common pitfall “We need better software” is the wrong conclusion to draw from most breaches. The decision-maker’s leverage is usually highest in the organisational layer — enforce multi-factor authentication, decommission dormant accounts, run an incident plan, audit supplier access — because those are governance choices a non-technical leader can actually mandate, whereas eliminating every software flaw is impossible.

Remark Analysing an attack surface is the first concrete deliverable of the course. Given a named organisation, you should be able to list plausible entry points and **sort them into the three layers** — and then say which layer offers the cheapest, highest- value mitigation. That sorting is the analytical skill; the layers are the tool.

3 Actors, zero-days, and the exploit market

A threat is only as real as the actor willing to use it. Who attacks, and why, determines what they will spend, how persistent they are, and therefore how you should defend. This chapter classifies the actors and then examines the unsettling market that arms them: the trade in **zero-day** vulnerabilities.

3.1 The four actor classes

Worked example — same tool, different hand. Two intrusions use almost identical ransomware. In the first, the goal is money: the operators negotiate, take payment, and move on — a business. In the second, the ransomware is a disguise; the real aim is to destroy data and sow chaos in a rival state’s infrastructure, and no genuine decryption key exists (this was NotPetya, 2017). Same apparent tool, completely different actor, motive, and appropriate response. You cannot defend against, or advise on, an attack you have not attributed.

Definition 3 The principal cybersecurity actor classes, by motivation and method:

- **State actors / APTs** (Advanced Persistent Threats) — government-backed groups pursuing espionage, sabotage, or strategic advantage; well-resourced, patient, and willing to develop or buy custom tools.
- **Criminal organisations** — profit-driven; ransomware, fraud, and data theft run as businesses, increasingly as *ransomware-as-a-service*.
- **Hacktivists** — ideologically motivated; disruption and exposure (leaks, defacements, DDoS) to make a political point.
- **Private security firms** — a dual-use category: defenders (incident response, threat intelligence) but also vendors of **offensive** tools and surveillance to governments.

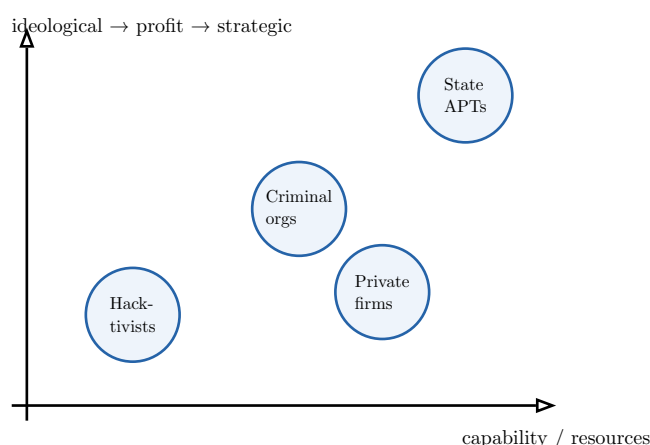


Figure 2: The actor landscape, arranged by capability (horizontal) and the nature of the motive. State APTs sit top-right: the most resources and the most strategic aims. Private offensive-security firms are placed deliberately in the middle — they sell capability that lifts a buyer’s position rightward, which is exactly why they are contentious.

You should be able to discuss at least **two named cases** per class. Canonical references: state APTs — APT28/APT29 (Russia) and the Lazarus Group (North Korea); criminal — the Conti and REvil ransomware groups; hacktivists — Anonymous and LulzSec; private firms — NSO Group (the Pegasus spyware vendor) and defensive players such as Mandiant.

Common pitfall Attribution is genuinely hard and routinely **politicised**. Attackers plant false flags (NotPetya’s fake ransom note), reuse each other’s tools, and operate through proxies precisely to blur the actor class. Treat confident public attribution as a **claim to be weighed**, noting who is making it and what evidence they offer — not as a settled fact.

3.2 Zero-days and the exploit market

Worked example — a key nobody knows is missing. Imagine discovering a master key that opens every lock of a given brand, and the lockmaker does not know the flaw exists. You could tell the lockmaker (who fixes it for everyone), sell the key to a government, sell it to burglars, or keep it for yourself. The key only keeps its value while the flaw stays **secret**. This is the situation a zero-day creates, and every one of those four choices is taken by real actors every day.

Definition 4 A **zero-day vulnerability** is a software flaw unknown to the vendor, for which no patch exists — defenders have had “zero days” to fix it. A **zero-day exploit** is working attack code for such a flaw. Because they cannot be patched in advance, zero-days are extraordinarily valuable, and a **legal-to-grey market** exists in which brokers buy exploits from researchers and sell them to governments and firms for sums reaching into the millions.

The market creates a sharp ethical and legal tension. A vulnerability researcher can **disclose** a flaw responsibly (improving everyone’s security) or **sell** it (where it may be used for surveillance or attack). The same knowledge is simultaneously a public-safety good and a weapon.

3.3 The state’s dilemma: stockpile or disclose

The tension is sharpest for governments, which face it as explicit policy.

Worked example — EternalBlue. The US NSA discovered a powerful flaw in Windows and, rather than report it to Microsoft, kept it as an offensive tool nicknamed *EternalBlue*. In 2017 the exploit leaked. Within weeks it powered the **WannaCry** ransomware (crippling, among others, the UK’s NHS) and **NotPetya**. The very capability the state had stockpiled for its own use was turned against hospitals and companies worldwide — the stockpile dilemma made concrete and catastrophic.

Definition 5 The **stockpile-vs-disclose dilemma**: when a state agency finds a zero-day, should it **disclose** it to the vendor (protecting everyone, including its own citizens and companies) or **retain** it for intelligence and offensive operations (gaining a capability, but leaving everyone exposed if anyone else finds — or steals — the same flaw)? Several governments run a formal process to weigh this; the US version is the *Vulnerabilities Equities Process*.

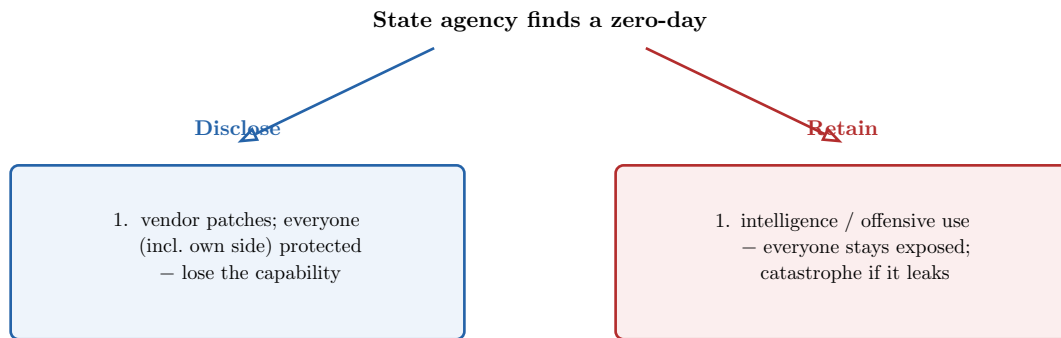


Figure 3: The stockpile-vs-disclose decision. EternalBlue is the cautionary tale for the right-hand branch: a retained exploit that leaked and was turned on civilian infrastructure. The dilemma has no clean answer — it is a genuine trade-off between a state’s offensive interest and the collective security of the systems its own citizens depend on.

4 Disinformation, influence operations, and information sovereignty

Not every attack targets a machine. Some target the **information environment** — what populations believe, trust, and decide. This chapter moves from attacks on systems to attacks on minds, and connects them back to the HUM24-2 regulatory architecture.

4.1 Disinformation versus misinformation

Worked example — the same false claim, two messengers. A false claim about a vaccine circulates. Person A shares it because they believe it and are worried for their family. Person B — running a covert state-linked network — manufactured and seeded the claim precisely to deepen social division, knowing it is false. The **content** is identical; the difference is **intent**. That difference is the entire distinction, and it changes both the diagnosis and the appropriate response.

Definition 6 **Misinformation** is false or misleading information spread **without intent to deceive** — error, rumour, sincere mistake. **Disinformation** is false or misleading information spread **deliberately**, as part of an intent to mislead, manipulate, or cause harm. An **influence operation** is an organised, often covert campaign — by a state or other actor — to shape opinion or behaviour in a target population, of which disinformation is one instrument.

Common pitfall Because intent is the dividing line, the same post can be disinformation at its origin and misinformation by the time it reaches you — the original manipulator knew it was false; the friend who forwards it does not. Do not classify a **piece of content** as one or the other in the abstract; classify the **act of a specific actor** spreading it. Conflating the two leads straight to bad policy that punishes confused citizens instead of the operators behind the campaign.

4.2 Anatomy of an influence operation

To analyse a documented operation you dissect it into four stages, asking what evidence exists at each.

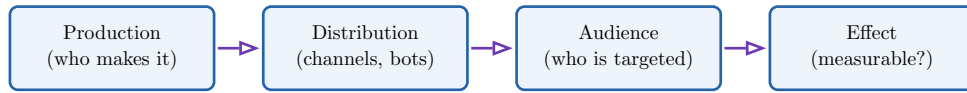


Figure 4: The four stages of an influence operation. A rigorous analysis follows the chain left to right and asks, at each stage, *what can actually be evidenced?* The hardest stage is the last: attributing a **measurable effect** on real-world behaviour is far harder than documenting that a campaign existed — a distinction careful analysts insist on.

Worked example — a documented operation. The Internet Research Agency (the St. Petersburg “troll factory”) ran a documented operation around the 2016 US election: **production** of fake personas and divisive content, **distribution** across social platforms and through purchased ads, a **target audience** segmented by political identity, and an **intended effect** of deepening polarisation and depressing certain turnout. Investigators could thoroughly document the first three stages; the fourth — how many votes actually moved — remains genuinely contested. Holding that distinction is what separates analysis from alarmism.

4.3 Information sovereignty

Influence operations and data flows lead states to a strategic claim: that control over the digital information environment is a matter of sovereignty.

Definition 7 Information sovereignty is a state’s claim to control the data, platforms, and digital infrastructure operating within or affecting its territory — including where data is stored, which platforms may operate, and what content circulates. It ranges from the EU’s data-protection and platform rules to far harder controls such as data- localisation mandates and national content filtering.

This is where the course rejoins HUM24-2’s regulatory architecture. The EU’s instruments are, read through this lens, assertions of information sovereignty encoding European values:

Instrument (HUM24-2)	Read as information sovereignty
GDPR	Asserts control over personal data — including limits on transferring Europeans’ data abroad — encoding privacy and dignity.
DSA	Asserts control over platform content and process — moderation duties, transparency, systemic-risk audits for very large platforms.
DMA	Asserts control over market structure — gatekeeper obligations to curb the power of dominant digital platforms.
EU AI Act	Asserts control over automated systems — risk tiers and deployer obligations, including limits on manipulative AI.

Table 2: The EU digital rulebook from HUM24-2, reframed as instruments of information sovereignty. Each encodes a value choice (privacy, accountable platforms, contestable markets) into an enforceable rule — the same “regulation as values-encoding architecture” thesis, now applied to the contest over who controls the information environment.

Remark Information sovereignty is double-edged, and a good analysis says so. The **same** argument — “a state should control its information environment” — underwrites both the EU’s rights-protective rules and authoritarian censorship regimes. The difference lies not in the sovereignty claim itself but in **what values it encodes** and **what constraints (rule of law, rights, oversight) bound it**. Naming that difference is the analytical task.

5 Risk assessment for digital assets

The course’s central practical skill is **risk assessment**: taking a specific digital asset and producing a structured analysis — probable threat actors, attack vectors, proportionate mitigations, and applicable law — that a non-technical decision-maker can act on.

Worked example — two assets, two risk profiles. A hospital’s patient-records database and a marketing startup’s email list are both “data.” But the hospital faces ransomware crews (who know hospitals pay to restore care) and must meet strict breach rules; the startup mainly faces credential stuffing and commodity phishing. Identical generic advice for both would be useless. Risk assessment is the discipline of producing advice that fits **this** asset.

5.1 The framework

Definition 8 A basic **risk assessment** for a digital asset proceeds in four steps:

1. **Identify the asset and its value** — what exactly are we protecting, and why does it matter (to us, and to an attacker)?
2. **Identify probable threat actors and attack vectors** — who would target this, and by what route (mapping vectors onto the technical / organisational / human attack surface)?
3. **Assess risk as likelihood $\times$ impact** — for each scenario, how probable is it and how bad would it be?
4. **Propose proportionate mitigations and the applicable regulatory framework** — controls whose cost matches the risk, plus the legal obligations that apply (notably GDPR’s 72-hour breach notification and, where relevant, NIS2).

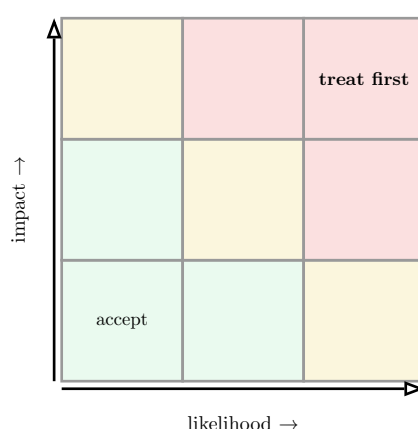


Figure 5: The likelihood $\times$ impact risk matrix. Each identified scenario is placed by how probable it is and how damaging it would be; the red corner (likely **and** high-impact) is treated first, the green corner (unlikely and minor) is accepted. The matrix is what makes mitigation **proportionate** — it stops you spending the budget on a vivid but improbable threat while ignoring the dull, likely one.

5.2 Proportionality and the decision-maker

Common pitfall The commonest failure in a student risk assessment is **disproportion**: recommending maximal security for everything. Infinite security is unaffordable and would halt the business. The skill is to **rank** risks on the matrix and match each mitigation's cost to the risk it removes — and to say plainly which low risks you are choosing to **accept**. A decision-maker needs a prioritised, costed shortlist, not a wishlist.

Remark The output is judged by whether a **non-technical** reader can act on it. That means: no unexplained jargon; risks stated in business terms (downtime, fines, lost trust); and an explicit link to legal exposure — “a breach here triggers GDPR’s 72-hour notification duty and a possible fine” is the kind of sentence a board understands and acts on. The next chapter gives you the regulatory vocabulary to write it.

6 The regulatory and institutional architecture

Cybersecurity is governed by a patchwork of agencies and laws. A decision-maker needs to know **who regulates, who enforces, and where the gaps are** — because the gaps are often the most important part.

6.1 The agencies

Definition 9 Three reference cybersecurity agencies, one per jurisdiction:

- **ANSSI** (France) — the national cybersecurity agency; sets standards, protects state and critical-infrastructure systems, and supports incident response.
- **ENISA** (EU) — the EU Agency for Cybersecurity; coordinates, advises, and builds capacity across member states, and underpins instruments like NIS2. It **advises and coordinates** more than it **enforces**.
- **CISA** (US) — the Cybersecurity and Infrastructure Security Agency; protects US federal networks and critical infrastructure and issues alerts and guidance.

6.2 The legal obligations

Definition 10 Two obligations you must be able to apply:

- **GDPR breach notification** — under GDPR (Article 33), a personal-data breach must be notified to the supervisory authority **within 72 hours** of becoming aware of it, where it risks individuals’ rights; affected individuals must be told if the risk is high.
- **NIS2** — the EU directive imposing **cyber-resilience** obligations (risk management, governance accountability, incident reporting) on operators of essential and important services, widening the older NIS regime to far more sectors.

Worked example — the clock starts ticking. A company discovers on Monday morning that customer data was exfiltrated. The GDPR clock does not wait for the full forensic picture: from the moment the firm is **aware** a breach has occurred, it has 72 hours to notify the regulator — even with incomplete information, supplemented later. Firms that treat notification as the last step after a leisurely investigation routinely **miss the deadline and compound the**

fine. The deadline is a governance obligation, not a technical one — which is why it belongs in a non-technical briefing.

6.3 Where the gaps are

Common pitfall Do not present this architecture as seamless. Its gaps are real and examinable: **jurisdiction** — attackers operate from states that will not extradite, so enforcement stops at the border; **fragmentation** — agencies coordinate imperfectly across countries; **advice-vs-enforcement** — bodies like ENISA largely advise and cannot compel; and **speed** — regulation moves in years while attacks move in hours. A briefing that names the relevant agency **and** the gap that limits it is worth far more than one that lists acronyms.

Body / rule	Scope	Limit / gap
ANSSI	France: standards, state & critical systems	National only; cross-border attacks need cooperation it cannot command.
ENISA	EU: coordination, advice, capacity	Largely advisory — coordinates rather than enforces.
CISA	US: federal networks, critical infrastructure	Much private infrastructure participates voluntarily.
GDPR 72h	Personal-data breach notification	Notification is not prevention; fines may not deter well-resourced attackers.
NIS2	Resilience duties for essential/important entities	Implementation varies by member state; coverage still has edges.

Table 3: The institutional architecture and its seams. The right-hand column is the analytically important one: knowing **who** regulates matters less than knowing **where their reach ends** — which is precisely where a real incident tends to land.

7 Cyber conflict and the incident briefing

The capstone of the course brings the threads together in two genres a professional must master: reading **cyber conflict as an instrument of state strategy**, and writing an **incident briefing** that a decision-maker can use.

7.1 Cyber conflict as a geopolitical instrument

Worked example — war below the threshold. A state wanting to weaken a rival can invade — costly, overt, and likely to provoke a hard response. Or it can disable the rival’s power grid for a few hours, deny involvement, and pay almost no diplomatic price. Cyber operations are attractive to states precisely because they sit **below the threshold** of armed conflict:

they are deniable, cheap relative to their effect, and hard to attribute. That is why so many of the incidents in this course have a state lurking behind them.

Definition 11 **Cyber conflict** is the use of cyber operations as an instrument of state strategy — for espionage, sabotage, coercion, or influence — typically **below the threshold** of conventional armed conflict. International norms governing it (what counts as an armed attack, what infrastructure is off-limits) remain contested and weakly enforced, which is part of the instrument’s appeal to states.

This is the bridge to *Geopolitics III*: behind a ransomware gang there may be a state tolerating or directing it; behind an influence operation, a foreign ministry; behind a wiper disguised as ransomware, an act of sabotage. Asking “**whose strategy does this serve?**” is the geopolitical reading the course requires.

7.2 Writing the incident briefing

The final deliverable is a written briefing on a real incident. It is not a technical write-up; it is a decision-useful analysis with a fixed structure.

Definition 12 A **cybersecurity incident briefing** covers, in order:

1. **The vulnerability exploited** — the specific weakness, sorted onto the attack- surface layer (technical, organisational, or human) where it really lived.
2. **The institutional failures that enabled it** — the governance, process, and oversight gaps, not just the technical bug.
3. **The measured impact** — quantified where possible (downtime, cost, people affected), separating documented impact from speculation.
4. **The lessons for organisational practice** — concrete, transferable changes a leader can mandate.
5. **The connection to a named state’s cybersecurity strategy** — situating the incident in the geopolitical contest where relevant.

Worked example — the structure applied to SolarWinds. **Vulnerability:** malicious code in a signed Orion update — a **supply-chain** compromise that weaponised trust. **Institutional failures:** insufficient scrutiny of the software supply chain and of privileged third-party access across thousands of organisations. **Impact:** 18,000 organisations received the tainted update, with a smaller number actively exploited, including US federal agencies; the full espionage cost is unquantifiable by design. **Lessons:** treat suppliers as part of your attack surface; monitor for anomalous behaviour, not just known-bad code. **State strategy:** widely attributed to a Russian state intelligence service and read as a strategic espionage operation — the geopolitical reading the briefing requires.

Common pitfall The two failure modes of an incident briefing are **over-technical** (a packet-level narrative no executive can use) and **under-evidenced** (asserting impacts and attribution the record does not support). Aim between them: structurally clear, honest about uncertainty — especially on attribution and on “measured” impact — and ending in actions a leader can actually take. Other reference incidents you should be ready to brief in this

structure include **Colonial Pipeline**, **NHS WannaCry**, and the **Uber 2022** breach (an MFA-fatigue social-engineering attack — a human-layer failure).

The through-line of the module. You moved from a vocabulary of **threats** (Ch. 1) to the **attack surface** that organises them and locates most real failures in the human and organisational layers (Ch. 2); from there to the **actors** and the **zero-day market** that arms them, with the stockpile dilemma at its heart (Ch. 3); then to attacks on the information environment — **disinformation**, **influence operations**, and **information sovereignty**, which reconnects to HUM24-2's regulatory architecture (Ch. 4). On that foundation you built a **risk-assessment** discipline for a concrete asset (Ch. 5), learned the **institutional architecture and its gaps** — ANSSI, ENISA, CISA, GDPR's 72-hour rule, NIS2 (Ch. 6) — and finally read **cyber conflict as state strategy** and learned to write a decision-useful **incident briefing** (Ch. 7). Throughout, the discipline is the same: treat cybersecurity as governance, attribute carefully, respect the evidence, and write for the decision-maker who has to act.